

Relatório de Auditoria de Segurança — Escolha Certa

30 de setembro de 2026 | pt-BR

Escopo: código Java, handlers MVC, acesso JPA, autenticação e autorização, templates Thymeleaf, JavaScript/CSS, migrations, configurações, testes, scripts, Docker e documentação.

Cinco categorias. Evidências verificáveis. Nenhuma alteração no código da aplicação.

A auditoria examina a cópia local recebida. Não certifica a implantação, o banco em execução ou a ausência de vulnerabilidades. A aplicação não foi executada neste ambiente.

Nota metodológica

RLS foi mapeado para a fronteira de autorização da API MVC: ADMIN global versus conteúdo público publicado. Gates do navegador foram cruzados com as rotas do CMS. IDOR foi revisto em todos os handlers e fluxos por ID. Segredos foram procurados nos arquivos de código e deploy. XSS foi mapeado para th:text/th:field, URLs e APIs DOM. Histórico Git e artefato compilado estavam indisponíveis.

Resumo executivo

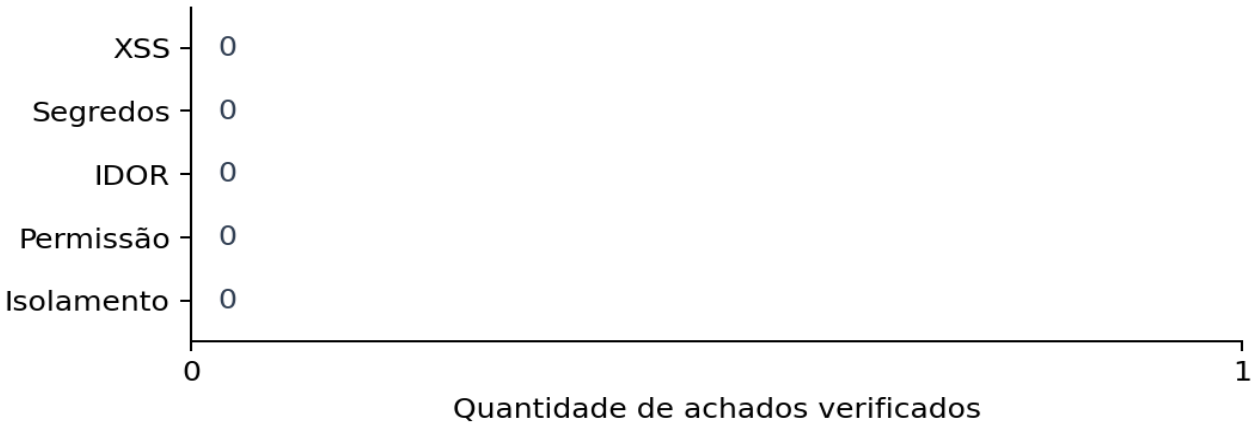
0 vulnerabilidades exploráveis verificadas nas cinco categorias

A cópia atual implementa controles coerentes com um CMS de uma única empresa. A ausência de achados é restrita ao código recebido e ao escopo solicitado; ainda há validações necessárias antes da publicação.

Crítica	Alta	Média	Baixa	Informativa
0	0	0	0	0



Rosca neutra: não há distribuição percentual quando o total é zero. Cores de severidade são reservadas para achados reais.



Stack detectada e fronteiras de confiança

Camada	Deteção / evidência
Linguagem e build	Java 17, Maven; pom.xml:2-3
Servidor	Spring Boot 3.5.16, Spring MVC; pom.xml:2,5
Banco e ORM	MySQL, Spring Data JPA/Hibernate, Flyway; pom.xml:8,13-14; V1__schema.sql:1-8
Autenticação	Spring Security, sessão e BCrypt custo 12; SecurityConfig.java:29-39,59-66. Sem JWT ou login de cliente/cuidador.
Frontend	25 templates Thymeleaf, site.js de 18 linhas e CSS estático. Sem SPA ou bundler. pom.xml:6,12
Deploy	Dockerfile multistage, Docker Compose de desenvolvimento e override local. Profiles dev/prod e storage local/S3. Sem CI/Helm/Terraform entregues.
Isolamento real	Acervo global da empresa. ADMIN pode gerir todo o acervo; visitantes veem publicados e criam leads. V1__schema.sql não contém tenant/user proprietário.

Como a revisão foi conduzida

Leitura e rastreamento dos 93 arquivos textuais inventariados, incluindo buscas de segredos e sinks. Foram percorridos todos os 31 handlers explícitos de PublicController e AdminController: 37 combinações método/padrão, sem expandir valores possíveis dos enums. Também foram verificados advice, serviços, repositories, handlers de recursos, login/logout e Actuator.

Não se aplica: isolamento entre tenants ou donos individuais, porque não existem esses atores no modelo atual. Aplicam-se: autorização administrativa, privacidade dos leads e estado de publicação. Não há e-mails HTML ou rich text implementados para auditar.

Limitações de cobertura

- O projeto entregue não contém .git; git log falhou. Histórico de commits e segredos removidos não puderam ser auditados.
- Não há JAR/bundle compilado ou source maps. Foram examinados todos os assets de frontend entregues: site.js, site.css e 25 templates.
- Maven, Docker e MySQL indisponíveis neste ambiente. Não houve execução da aplicação, suíte JUnit, pentest HTTP ou inspeção do banco em execução.
- Não foram inspecionados .env do computador do usuário, secrets de nuvem, proxy, IAM, buckets ou pipeline externa. Não há CI, Helm ou Terraform no pacote.
- Sem resolução Maven ou varredura CVE das dependências transitivas; esses controles estão fora das cinco categorias solicitadas.

Resultados nas cinco categorias

Isolamento

Sem falha verificada. Tenant/dono não se aplica ao modelo atual: uma empresa, administradores globais, visitantes anônimos. A fronteira real é ADMIN versus dados publicados. Não há Supabase/RLS, middleware tenant ou contas de clientes/cuidadores. Alterar esse modelo exige nova autorização em queries e objetos.

Permissão no navegador

Sem falha verificada. Não existem gates isAdmin/canEdit/role no JS ou sec:authorize nos templates. O menu administrativo é renderizado em views do CMS; todos os destinos sensíveis são /admin e recebem hasRole(ADMIN) no servidor. Os th:if de published controlam apresentação, não substituem a guarda do backend.

IDOR

Sem falha verificada. Todos os 31 handlers foram examinados, abrangendo 37 combinações método/padrão de rota. IDs administrativos pertencem ao acervo global acessível a ADMIN. Blog e formulários por ID verificam publicação. Troca de senha escolhe a conta pelo Principal. Não existe endpoint público que leia ou altere lead por ID.

Segredos

Sem segredo real de produção hardcoded verificado nos arquivos recebidos. Credencial fixa de testes encontrada e explicitamente segregada (application-test.yml:11-12, ApplicationFlowTest.java:50-52, README.md:96). É recurso de src/test, não src/main; copiar para produção ou publicar banco de teste tornaria a credencial conhecida, mas isso não foi observado. Há validação da senha inicial; não há blacklist de senhas conhecidas. Histórico Git e artefato compilado indisponíveis.

XSS

Sem falha verificada. Nenhum sink th:utext, innerHTML, eval, new Function ou equivalente encontrado no código de produção. Textos, erros, JSON e respostas são exibidos com escape/contextos de texto. URLs são prefixadas/validadas. Não há biblioteca de sanitização: o produto não aceita rich text/Markdown/HTML e evita a interpretação de HTML. Não há fluxo de envio de e-mail implementado.

Pontos fracos centrais / riscos residuais

Não foi demonstrada uma falha explorável nas categorias solicitadas. Os principais limites para a decisão de publicar são a falta de revisão do histórico e da implantação e a ausência de validação dinâmica. A arquitetura concede a qualquer administrador autenticado o acervo inteiro por definição; ela precisará mudar se houver clientes autenticados ou múltiplas empresas.

Pontos fortes com evidência no código

Os trechos abaixo são da cópia auditada. Linhas de HTML estão minificadas em uma única linha; o excerto preserva o número real dessa linha. Os arquivos completos e hashes constam no inventário.

S01 | Autorização central de todo o CMS

src/main/java/br/com/escolhacerta/security/SecurityConfig.java:54-58

Todos os 21 handlers administrativos estão sob /admin. `hasRole("ADMIN")` é executado no servidor antes do controller; o menu não constitui a autorização.

```
54:         .authorizeHttpRequests(auth -> auth
55:             .requestMatchers("/admin/**").hasRole("ADMIN")
56:             .requestMatchers("/actuator/health", "/actuator/health/**").permitAll()
57:             .requestMatchers("/actuator/**").denyAll()
58:             .anyRequest().permitAll())
```

S02 | Listagens públicas somente de conteúdos publicados

src/main/java/br/com/escolhacerta/service/ContentService.java:17-18

A consulta pública usa filtro `published=true`. As consultas globais sem esse filtro são usadas pelo CMS protegido.

```
17:     public java.util.List<Content> published(ContentKind kind) {
18:         return repo.findByKindAndPublishedTrueOrderBySortOrderAscCreatedAtDesc(kind);
```

S03 | Blog não expõe rascunhos por troca de ID

src/main/java/br/com/escolhacerta/service/ContentService.java:26-29

A leitura por ID exige publicação e tipo POST; falha retorna 404.

```
26:     public Content publicPost(long id) {
27:         Content c=get(id);
28:         if(!c.getPublished()||c.getKind()!=ContentKind.POST)throw new
29:             ResponseStatusException(HttpStatus.NOT_FOUND);
30:         return c;
```

S04 | Formulários públicos validam o estado em GET e POST

src/main/java/br/com/escolhacerta/controller/PublicController.java:78-92

GET e POST chamam `publicForm`, que rejeita rascunho; POST grava uma nova solicitação, sem dar acesso a respostas de terceiros.

```
86:     private CustomForm publicForm(long id) {
87:         CustomForm f=forms.get(id);
88:         if(!f.getPublished())throw new
89:             org.springframework.web.server.ResponseStatusException(org.springframework.http.HttpStatus.NOT_FOUND);
90:         return f;
```

S05 | Senha alterada somente na própria conta autenticada

src/main/java/br/com/escolhacerta/controller/AdminController.java:176-183

Não aceita user_id ou e-mail do navegador para escolher a conta. Obtém Principal e confere a senha atual.

```
176: @PostMapping("/account") public String password(@RequestParam String currentPassword,@RequestParam
String newPassword,@RequestParam String confirmPassword,java.security.Principal principal,Model
m,RedirectAttributes flash,jakarta.servlet.http.HttpServletRequest request) {
177:     AdminUser user=users.findByEmail(principal.getName()).orElseThrow();
178:     if(!encoder.matches(currentPassword,user.getPasswordHash())||newPassword.length()<12||newPasswo
rd.getBytes(java.nio.charset.StandardCharsets.UTF_8).length>72||!newPassword.equals(confirmPassword)) {
179:         m.addAttribute("error","Verifique a senha atual e use uma nova senha entre 12 e 72
caracteres, com confirmação igual.");
180:         return "admin/account";
181:     }
182:     user.setPasswordHash(encoder.encode(newPassword));
183:     users.save(user);
```

S06 | Senha inicial de produção não é um default público

src/main/java/br/com/escolhacerta/config/AdminBootstrap.java:21-27

Bootstrap de banco sem administrador rejeita e-mail inválido e senha com menos de 12 caracteres ou mais de 72 bytes; salva apenas o hash.

```
21: public void run(ApplicationArguments args) {
22:     if(repo.count()==0) {
23:         if(!email.matches("[^@\\s]+@[^@\\s]+\\.([^@\\s]+)")||password.length()<12||password.getBytes(j
ava.nio.charset.StandardCharsets.UTF_8).length>72)throw new IllegalStateException("Configure ADMIN_EMAIL e
ADMIN_PASSWORD com pelo menos 12 caracteres");
24:         AdminUser user=new AdminUser();
25:         user.setEmail(email.toLowerCase());
26:         user.setPasswordHash(encoder.encode(password));
27:         repo.save(user);
```

S07 | Compose exige segredos externos

docker-compose.yml:7-9

As expansões :? interrompem a configuração se senhas de banco não estiverem definidas; nenhum valor secreto padrão é embutido.

```
7: MYSQL_USER: ${DB_USER:?Execute o script de inicialização}
8: MYSQL_PASSWORD: ${DB_PASSWORD:?Execute o script de inicialização}
9: MYSQL_ROOT_PASSWORD: ${DB_ROOT_PASSWORD:?Execute o script de inicialização}
```

S08 | Senhas geradas criptograficamente

scripts/init.sh:6-12

OpenSSL gera 24 bytes aleatórios por segredo. PowerShell usa RandomNumberGenerator (init.ps1:5-11).

```
6: cp .env.example .env
7: for key in DB_PASSWORD DB_ROOT_PASSWORD ADMIN_PASSWORD; do
8:     value=$(openssl rand -hex 24)
9:     sed -i.bak "s/^\${key}=.*\/\${key}=${value}/" .env
10:     rm -f .env.bak
11: done
12: chmod 600 .env
```

S09 | Conteúdo e mensagens renderizados como texto

src/main/resources/templates/post.html:1-1

post.body usa th:text. lead-detail.html:1 também usa th:text para mensagem e respostas. Nenhuma saída HTML não escapada foi encontrada.

```
1: <div class="preserve article-body" th:text="${post.body}"></div>
```

S10 | DOM do editor não interpreta HTML recebido

src/main/resources/static/js/site.js:11-15

JSON.parse não avalia código; campos usam value e textContent; elementos são criados com createElement.

```
11: let fields;try{fields=JSON.parse(source.value);if(!Array.isArray(fields))throw
Error();}catch(e){fields=[];}
14: const input=(label,value,onChange,type='text')=>{const
wrap=document.createElement('label');wrap.textContent=label;const element=document.createElement('input');el
ement.type=type;element.value=value||'';element.maxLength=type==='text'?100:2000;element.addEventListener('i
nput',()=>onChange(element.value));wrap.appendChild(element);return wrap;};
```

S11 | URL de imagem validada no servidor

src/main/java/br/com/escolhacerta/dto/ContentForm.java:6-11

Permite HTTPS ou caminho local de imagem PNG/JPG. javascript: e data: não satisfazem a expressão. Binding recebe @Valid em AdminController:70.

```
6: @NotBlank @Size(max=180) public String title;
7: @Size(max=500) public String summary;
8: @Size(max=30000) public String body;
9: @Size(max=1000) @Pattern(regexp="^(?!https://[^\s]+$|^/media/[a-f0-9-]+\.\.(png|jpg)$",message="Use
uma URL HTTPS ou uma imagem enviada pelo painel") public String imageUrl="";
10: public boolean published;
11: @Min(0) @Max(10000) public int sortOrder;
```

S12 | Upload público contém somente imagens regravadas

src/main/java/br/com/escolhacerta/service/UploadService.java:13-29

Formato real PNG/JPEG, dimensões e tamanho limitados, decodificação/regravação. Não preserva HTML/SVG ou nome arbitrário do remetente.

```
20: String format=reader.getFormatName().toLowerCase();
21: if(!java.util.Set.of("png","jpeg","jpg").contains(format))throw new
IllegalArgumentException("Use PNG ou JPEG");
27: if(!javax.imageio.ImageIO.write(image,ext,output))throw new
IllegalArgumentException("Não foi possível processar a imagem");
```

S13 | Autenticação e proteção adicional

src/main/java/br/com/escolhacerta/security/SecurityConfig.java:29-39

BCrypt custo 12 e papel ADMIN atribuído pelo servidor. CSRF não está desabilitado; configura CSP sem scripts inline (69-72).

```
29: @Bean
30: PasswordEncoder passwordEncoder() {
31:     return new BCryptPasswordEncoder(12);
32: }
33:
34: @Bean
35: UserDetailsService users(AdminUserRepository repo) {
36:     return username -> repo.findByEmail(username.toLowerCase())
37:         .map(user -> User.withUsername(user.getEmail())
38:             .password(user.getPasswordHash()).roles("ADMIN").build())
39:         .orElseThrow(() -> new UsernameNotFoundException("Credenciais inválidas"));
```

S14 | Navegação e campos dinâmicos têm destinos restritos

src/main/java/br/com/escolhacerta/dto/SettingsForm.java:6-10

WhatsApp somente dígitos, prefixo wa.me fixo (layout.html:3), e-mail validado com prefixo mailto: fixo.

FieldDefinition.java:5 restringe tipos e nomes; FormService.java:33 reserva nomes técnicos.

```
6:      @Email @Size(max=180) public String email;
7:      @Size(max=30) public String phone;
8:      @Pattern(regex="[0-9]{0,15}",message="Use apenas números, incluindo DDI e DDD") public String
whatsapp;
9:      @Size(max=120) public String city;
10:     @Size(max=5000) public String about;
```

Tabela de achados por categoria

Nenhum registro de vulnerabilidade confirmou uma condição explorável. “Sem achado” é um resultado de revisão, não uma severidade e não uma aprovação de produção.

Severidade	Arquivo:linha	Descrição
Não atribuída	Não se aplica	Sem achado verificado: Isolamento
Não atribuída	Não se aplica	Sem achado verificado: Permissão no navegador
Não atribuída	Não se aplica	Sem achado verificado: IDOR
Não atribuída	Não se aplica	Sem achado verificado: Segredos
Não atribuída	Não se aplica	Sem achado verificado: XSS

Legenda de chips de severidade

CRÍTICA	ALTA	MÉDIA	BAIXA	INFORMATIVA
---------	------	-------	-------	-------------

A tabela está vazia de achados porque não foi comprovada uma falha, e não por falta de aplicação das cinco categorias. Os controles e as limitações são apresentados separadamente para evitar confundir evidência correta com vulnerabilidade.

Credencial de teste observada e classificada

```
src/test/resources/application-test.yml
11:   email: admin@test.local
12:   password: TesteSeguro123456
```

Severidade de vulnerabilidade: não atribuída. A senha pertence aos testes e não há recurso equivalente em src/main. README.md:96 declara seu uso apenas no banco de teste. Não foi observado deploy desse banco ou inclusão de test resources no artefato final. Se houver essa configuração na nuvem, ela deve ser corrigida; não é uma condição demonstrada nesta cópia.

Cobertura integral dos handlers MVC

Base dos caminhos de arquivos abaixo: `src/main/java/br/com/escolhacerta/controller/`. Todos os handlers de `AdminController` recebem a guarda `SecurityConfig.java:55`. Os IDs administrativos representam objetos globais autorizados para esse papel.

Método / caminho	Handler / evidência	Controle verificado
GET /	PublicController.java: 22 home	ContentService.java:17-18: consulta somente <code>published=true</code> .
GET /servicos, /blog, /depoimentos	PublicController.java: 28 listing	ContentService.java:17-18: consulta somente <code>published=true</code> .
GET /blog/{id}	PublicController.java: 39 post	ContentService.java:26-29: <code>published=true</code> e <code>kind=POST</code> ; caso contrário 404.
GET /sobre	PublicController.java: 43 about	Página pública; não retorna registros privados.
GET /privacidade	PublicController.java: 46 privacy	Página pública; não retorna registros privados.
GET /login	PublicController.java: 49 login	Página pública; não retorna registros privados.
GET /orcamento, /sou-cuidador, /contato	PublicController.java: 60 form	Página pública; não retorna registros privados.
POST /orcamento, /sou-cuidador, /contato	PublicController.java: 68 submit	Entrada pública @Valid LeadForm; cria registro novo; sem ID de lead fornecido.
GET /formularios/{id}	PublicController.java: 78 custom	PublicController.java:86-89: exige <code>published=true</code> . POST apenas cria lead; não altera formulário.
POST /formularios/{id}	PublicController.java: 91 customSubmit	PublicController.java:86-89: exige <code>published=true</code> . POST apenas cria lead; não altera formulário.
GET /admin	AdminController.java: 38 dashboard	ADMIN no servidor (SecurityConfig.java:55); escopo global da empresa.
GET /admin/contents/{kind}	AdminController.java: 45 contents	ADMIN no servidor (SecurityConfig.java:55); escopo global da empresa.
GET /admin/contents/{kind}/new	AdminController.java: 50 contentNew	ADMIN no servidor (SecurityConfig.java:55); escopo global da empresa.
GET /admin/contents/{kind}/{id}/edit	AdminController.java: 55 contentEdit	ADMIN no servidor (SecurityConfig.java:55); escopo global da empresa. Verificação de kind (Controller:57/79; Service:33).
POST /admin/contents/{kind}/save	AdminController.java: 70 contentSave	ADMIN no servidor (SecurityConfig.java:55); escopo global da empresa. Verificação de kind (Controller:57/79; Service:33).
POST /admin/contents/{kind}/{id}/delete	AdminController.java: 78 contentDelete	ADMIN no servidor (SecurityConfig.java:55); escopo global da empresa. Verificação de kind (Controller:57/79; Service:33).

Método / caminho	Handler / evidência	Controle verificado
GET /admin/leads	AdminController.java: 83 inbox	ADMIN no servidor (SecurityConfig.java:55); escopo global da empresa.
GET /admin/leads/{id}	AdminController.java: 89 lead	ADMIN no servidor (SecurityConfig.java:55); escopo global da empresa.
POST /admin/leads/{id}/status	AdminController.java: 93 status	ADMIN no servidor (SecurityConfig.java:55); escopo global da empresa.
POST /admin/leads/{id}/delete	AdminController.java: 97 deleteLead	ADMIN no servidor (SecurityConfig.java:55); escopo global da empresa.
GET /admin/forms	AdminController.java: 101 forms	ADMIN no servidor (SecurityConfig.java:55); escopo global da empresa.
GET /admin/forms/new	AdminController.java: 105 formNew	ADMIN no servidor (SecurityConfig.java:55); escopo global da empresa.
GET /admin/forms/{id}/edit	AdminController.java: 111 formEdit	ADMIN no servidor (SecurityConfig.java:55); escopo global da empresa.
POST /admin/forms/save	AdminController.java: 122 formSave	ADMIN no servidor (SecurityConfig.java:55); escopo global da empresa.
POST /admin/forms/{id}/delete	AdminController.java: 134 formDelete	ADMIN no servidor (SecurityConfig.java:55); escopo global da empresa.
GET /admin/settings	AdminController.java: 138 settings	ADMIN no servidor (SecurityConfig.java:55); escopo global da empresa.
POST /admin/settings	AdminController.java: 149 settingsSave	ADMIN no servidor (SecurityConfig.java:55); escopo global da empresa.
GET /admin/media	AdminController.java: 161 media	ADMIN no servidor (SecurityConfig.java:55); escopo global da empresa.
POST /admin/media	AdminController.java: 164 upload	ADMIN no servidor (SecurityConfig.java:55); escopo global da empresa.
GET /admin/account	AdminController.java: 173 account	ADMIN no servidor (SecurityConfig.java:55); escopo global da empresa.
POST /admin/account	AdminController.java: 176 password	ADMIN; conta obtida do Principal, senha atual conferida (176-178); invalida sessões (184-192).

Rotas e hooks fora dos handlers explícitos

- POST /login e POST /logout: filtros Spring Security, SecurityConfig.java:59-63. Login autentica; logout é POST com CSRF padrão.
- GET /actuator/health e probes: SecurityConfig.java:56-57; application.yml:47-59. Somente health é exposto, sem detalhes.
- GET /media/**: WebConfig.java:10-11; somente imagens aceitas por UploadService.java:13-29. GET /css/**, /js/** e /images/**: recursos estáticos públicos.
- /error: handler automático Spring Boot, ErrorAdvice.java:8-10 e templates error/*.html, sem dados privados por ID.
- GlobalViewAdvice.java:14-18: configurações públicas da empresa id 1 e formulários publicados.

Cruzamento de UI, endpoints e consultas

View / gate	Endpoint / guarda de backend
admin/contents.html:1; content-edit.html:1	/admin/contents/**: listar, novo, editar, salvar, excluir. AdminController.java:45,50,55,70,78; SecurityConfig.java:55.
admin/leads.html:1; lead-detail.html:1	/admin/leads/**: listar, ler, status, excluir. AdminController.java:83,89,93,97; SecurityConfig.java:55.
admin/forms.html:1; form-edit.html:1	/admin/forms/**: listar, novo, editar, salvar, excluir. AdminController.java:101,105,111,122,134; SecurityConfig.java:55.
admin/settings.html:1; media.html:1; account.html:1	/admin/settings, /admin/media, /admin/account GET/POST: AdminController.java:138,149,161,164,173,176; SecurityConfig.java:55.
fragments/layout.html:5	Menu do CMS não faz gate por role no navegador. Dashboard /admin:38 e todos os destinos acima são protegidos no servidor.
forms.html:1 - th:if published	Gate de apresentação. /formularios/{id} GET/POST também valida published em PublicController.java:86-92.
listing.html:1; home.html:1	Gate de apresentação do tipo de conteúdo, não de privilégio. PublicController usa ContentService.published; rota blog por ID usa publicPost.

Repositories e consultas globais

ContentRepository.java:7-8 separa publicado de global. CustomFormRepository.java:7 filtra publicação; findAll é usado apenas no CMS. LeadRepository.java:7-8 (findByKind/countByStatus), findAll/count e findById chegam ao inbox/dashboard protegidos. AdminUserRepository.java:7 é usado na autenticação e na troca da própria senha. SiteSettingsRepository usa somente id 1 de configuração pública. Não há relatórios, exportações, GraphQL, API REST adicional ou SQL/query builder construído com entrada recebida.

Inventário arquivo por arquivo

Base: EscolhaCerta/. Cada intervalo cobre o arquivo textual completo lido. Inclui deploy, scripts e testes. SHA-256 completo disponível em audit-data.json e cobertura-auditoria.md para identificar a cópia examinada. Arquivos gerados pela auditoria não entram no escopo de código original.

Arquivo	Linhas verifi cadas	Hash SHA-256 (prefixo)
.dockerignore	1-6	a9e321012d71e0f4
.env.example	1-21	8b1d498a73acd36a
.gitignore	1-9	36dfc7b6d70f5913
Dockerfile	1-17	1bf08509c190aef3
README.md	1-149	7d17b54a86385b4e
docker-compose.local.yml	1-5	124c6d80bd3e8741
docker-compose.yml	1-39	9973cf69b52d6e0e
docs/DEPLOY.md	1-52	a4d930d4e4042db6
docs/REFERENCES.md	1-9	a09a2f968bc60cca
docs/SECURITY_REVIEW.md	1-59	256350d6787724f8
docs/UPDATE.md	1-40	32104640a1c5bb02
docs/VALIDATION.md	1-53	4b9479af0b8157a2
pom.xml	1-19	944c7f8cfc096cb8
scripts/init.ps1	1-14	7349a2dff00b9ec3
scripts/init.sh	1-13	e99e948b245c77f5
scripts/run-local.ps1	1-7	7c16a536d33aabb2
scripts/run-local.sh	1-9	81e56ab5e3c71629
scripts/smoke.py	1-36	b68ae970686936c2
scripts/start.ps1	1-6	2ce97b5d820b01a6
scripts/start.sh	1-6	bc123ebbab0d2008
scripts/test.sh	1-4	b955fdef246912ea
src/main/java/br/com/escolhacerta/EscolhaCertaApplication.java	1-10	bf0c3720b24abb61
src/main/java/br/com/escolhacerta/config/AdminBootstrap.java	1-30	3e3c7a2d85ddd151
src/main/java/br/com/escolhacerta/config/WebConfig.java	1-13	9d840bc36f60dc72

Arquivo	Linhas verifi cadas	Hash SHA-256 (prefixo)
src/main/java/br/com/escolhacerta/controller/AdminController.java	1-195	c09a6298d6cf31f8
src/main/java/br/com/escolhacerta/controller/ErrorAdvice.java	1-12	132922600cd10a08
src/main/java/br/com/escolhacerta/controller/GlobalViewAdvice.java	1-20	9d89c53a2f544858
src/main/java/br/com/escolhacerta/controller/PublicController.java	1-108	b006262f53f0659d
src/main/java/br/com/escolhacerta/dto/ContentForm.java	1-48	1ba559fe72289bb2
src/main/java/br/com/escolhacerta/dto/CustomFormDto.java	1-34	659c3c0fc69745e6
src/main/java/br/com/escolhacerta/dto/FieldDefinition.java	1-6	5808970e5b101e35
src/main/java/br/com/escolhacerta/dto/LeadForm.java	1-55	bdc7f496f24b54b7
src/main/java/br/com/escolhacerta/dto/SettingsForm.java	1-41	779f0d4b05249065
src/main/java/br/com/escolhacerta/model/AdminUser.java	1-28	37247eb00de27807
src/main/java/br/com/escolhacerta/model/Content.java	1-70	5a79a413227e119b
src/main/java/br/com/escolhacerta/model/ContentKind.java	1-5	94725551c772c598
src/main/java/br/com/escolhacerta/model/CustomForm.java	1-42	11a7953b2e01f3d9
src/main/java/br/com/escolhacerta/model/Lead.java	1-91	524980b57fc9148c
src/main/java/br/com/escolhacerta/model/LeadKind.java	1-5	644653770c057a72
src/main/java/br/com/escolhacerta/model/LeadStatus.java	1-5	8e3e086bfcf3b9f6
src/main/java/br/com/escolhacerta/model/SiteSettings.java	1-49	a8d041592f71d44d
src/main/java/br/com/escolhacerta/repository/AdminUserRepository.java	1-8	c6156c7177ab48ff
src/main/java/br/com/escolhacerta/repository/ContentRepository.java	1-9	b77477e1587877d4
src/main/java/br/com/escolhacerta/repository/CustomFormRepository.java	1-8	64571c8e080b1711
src/main/java/br/com/escolhacerta/repository/LeadRepository.java	1-9	3aa5681ea29a2db1
src/main/java/br/com/escolhacerta/repository/SiteSettingsRepository.java	1-7	c8871e6ea844f75b
src/main/java/br/com/escolhacerta/security/RateLimitFilter.java	1-54	d2331cb295976123
src/main/java/br/com/escolhacerta/security/SecurityConfig.java	1-75	b6ec90f4f2d5d142
src/main/java/br/com/escolhacerta/service/ContentService.java	1-49	c9d8e744e1e821c6
src/main/java/br/com/escolhacerta/service/FormService.java	1-82	71d12eded0c37820
src/main/java/br/com/escolhacerta/service/LeadService.java	1-42	b492d96c25ad522a

Arquivo	Linhas verifi cadas	Hash SHA-256 (prefixo)
src/main/java/br/com/escolhacerta/service/UploadService.java	1-39	12605d85ad213eef
src/main/java/br/com/escolhacerta/storage/LocalMediaStorage.java	1-24	0ae280ce662a2ad5
src/main/java/br/com/escolhacerta/storage/MediaStorage.java	1-5	32761a54fb2074d8
src/main/java/br/com/escolhacerta/storage/S3MediaStorage.java	1-30	26a9657dcf394c21
src/main/resources/application-dev.yml	1-6	90f98e71f0f9933d
src/main/resources/application-prod.yml	1-15	4fd25edcca915a1c
src/main/resources/application.yml	1-70	aa8103219ab08395
src/main/resources/db/migration/V1__schema.sql	1-8	e804d4677479df06
src/main/resources/db/migration/V2__initial_content.sql	1-12	08c682aa696add3f
src/main/resources/db/migration/V3__company_whatsapp.sql	1-5	0a9f2a9fb973e38c
src/main/resources/db/migration/V4__remove_childcare_service.sql	1-3	1c6e42107855908d
src/main/resources/static/css/site.css	1-44	129f99b8d20706dd
src/main/resources/static/js/site.js	1-18	137cf66483c6701b
src/main/resources/templates/about.html	1-1	be10be0f51ffd777
src/main/resources/templates/admin/account.html	1-1	35e18e310e2b026b
src/main/resources/templates/admin/content-edit.html	1-1	8ac1724b569f2517
src/main/resources/templates/admin/contents.html	1-1	aa0ef0cb0d38fda7
src/main/resources/templates/admin/dashboard.html	1-1	f4e0adf8d2a1c49a
src/main/resources/templates/admin/form-edit.html	1-1	8b7401eedf89d63e
src/main/resources/templates/admin/forms.html	1-1	c7222ef4c823c2c0
src/main/resources/templates/admin/lead-detail.html	1-1	2e1a3db891d9f0ea
src/main/resources/templates/admin/leads.html	1-1	b66cd1d4bed16c89
src/main/resources/templates/admin/media.html	1-1	d51ba029c1cce41e
src/main/resources/templates/admin/settings.html	1-1	309ba6141e0b3f2b
src/main/resources/templates/custom-form.html	1-1	a5c090f3cda7a8d2
src/main/resources/templates/error/403.html	1-1	5f76cbd67c50551c
src/main/resources/templates/error/404.html	1-1	c4330aeba35ca23b

Arquivo	Linhas verifi cadas	Hash SHA-256 (prefixo)
src/main/resources/templates/error/429.html	1-1	5d592f35f31118d5
src/main/resources/templates/error/500.html	1-1	12f4121e92c386f0
src/main/resources/templates/error.html	1-1	df3fc2a0b0526634
src/main/resources/templates/fragments/form.html	1-1	c658965a9c257e84
src/main/resources/templates/fragments/layout.html	1-6	aae1a03cf7eea283
src/main/resources/templates/home.html	1-7	458290a6a4321655
src/main/resources/templates/lead-form.html	1-1	2c5e557e48d5aa02
src/main/resources/templates/listing.html	1-1	1d4e24d2720842b3
src/main/resources/templates/login.html	1-1	7acef54c55bf6c2f
src/main/resources/templates/post.html	1-1	60a63ef772d7fb8f
src/main/resources/templates/privacy.html	1-1	f611ff96db5d0bb8
src/test/java/br/com/escolhacerta/ApplicationFlowTest.java	1-140	9ee2df6243fe7e42
src/test/java/br/com/escolhacerta/FormValidationTest.java	1-24	89e63672217bcbef
src/test/java/br/com/escolhacerta/RateLimitSecurityTest.java	1-28	c5de1e01a65a4b25
src/test/resources/application-test.yml	1-15	3809b96a52b4c6c4

Assets binários

static/images/logo-wide.png e logo.jpg: imagens do frontend, sem revisão de metadados binários. Nenhum bundle/JAR compilado foi fornecido. A auditoria de segredos de frontend cobre os assets textuais efetivamente entregues, não um build inexistente.

Recomendações priorizadas

Pendências para publicar, sem confundi-las com achados de vulnerabilidade. Não é necessário criar issues de segurança fictícias para registrar essas tarefas.

P1

Validar a aplicação real em staging: mvn -B verify, Docker/MySQL e smoke.py em base de teste. Acrescentar/rodar uma matriz negativa para todas as rotas do CMS (anônimo e papel USER), leitura de rascunhos em GET/POST e payloads XSS em campos e erros. Os testes existentes foram lidos, não executados.

P1

Auditar o repositório Git completo e o JAR da release: histórico de todos os refs, tags e branches, resources empacotados e assets finais. Confirmar ausência de .env e de application-test.yml no JAR; rotacionar qualquer credencial real encontrada.

P2

Conferir a implantação: profile prod, HTTPS/cookie Secure, TLS no MySQL, secrets exclusivos, banco sem acesso público e storage externo limitado ao prefixo de imagens. O Compose recebido é dev e não prova a configuração da nuvem.

P3

Manter texto simples escapado no CMS. Se rich text/Markdown for adicionado, implementar sanitização por allowlist nos sinks e testar URLs/protocolos. Se contas de clientes ou tenants forem adicionadas, redesenhar as queries e verificações de posse antes de ativar os novos endpoints.

Reprodução do relatório

O gerador lê audit-data.json e recompõe o PDF; ele não refaz a revisão do código. Após uma mudança, atualizar evidências, linhas, hashes e achados antes de regerar. Use Python em venv e requirements.txt; comando: python generate_report.py. DejaVu Sans e DejaVu Sans Mono precisam estar disponíveis; AUDIT_FONT_DIR permite apontar o diretório de fontes.

ISSUES PARA O GITHUB

Nenhum achado acionável de vulnerabilidade foi verificado nesta auditoria das cinco categorias. Não há issues de vulnerabilidade para copiar nesta versão do relatório.

As limitações de acesso e as tarefas de validação são registradas nas seções anteriores. Elas não demonstram exploração e, portanto, não receberam títulos, labels ou severidades de vulnerabilidade inventados.

O arquivo issues-github.md acompanha o relatório com o mesmo resultado. Caso uma nova auditoria confirme um achado, cada issue deve conter título [Segurança], labels security + severidade, evidência exata, impacto, correção e critérios de aceite, delimitada por --- ISSUE n --- e --- FIM ISSUE n ---.